

Rencana Uji Integrasi Protokol AAA (Authentication, Authorization, Accounting)

Rencana pengujian integrasi untuk protokol Keamanan Informasi (AAA) yang diimplementasikan pada sistem IPB-Lost-Found. Pengujian ini bertujuan untuk memastikan bahwa mekanisme keamanan berjalan sesuai dengan spesifikasi dan standar keamanan yang ditetapkan.

1. Authentication (Autentikasi)

Tujuan: Memastikan sistem dapat memverifikasi identitas pengguna dengan benar dan mencegah akses oleh pihak yang tidak memiliki kredensial sah, termasuk pengujian pada fitur MFA (Multi-Factor Authentication).

Skenario Pengujian:

ID	Fitur	Skenario Pengujian	Hasil yang Diharapkan (Expected Result)
AUTH-01	Registrasi	Mendaftar dengan email dan password valid	Berhasil terdaftar, password di-hash (bcrypt) di database
AUTH-02	Registrasi	Mendaftar dengan email yang sudah ada	Gagal, sistem menolak duplikasi dengan pesan error 400
AUTH-03	Login Valid	Login dengan kredensial yang benar	Sistem mengembalikan Access Token dan Refresh Token (JWT)
AUTH-04	Login Invalid	Login dengan password atau email salah	Gagal, akses ditolak dengan error 401 Unauthorized
AUTH-05	Refresh Token	Memperbarui token menggunakan Refresh Token	Token baru diterbitkan dengan masa berlaku baru
AUTH-06	Multi-Factor Auth (MFA)	Melakukan login ketika MFA aktif	Sistem meminta OTP, login belum selesai sebelum OTP valid
AUTH-07	Verifikasi OTP	Mengirim kode OTP yang benar via /verify-otp	Login sukses, Access Token diberikan
AUTH-08	Verifikasi OTP Invalid	Mengirim kode OTP yang salah/kedaluwarsa	Verifikasi gagal dengan kode 401

2. Authorization (Otorisasi)

Tujuan: Memastikan pengguna hanya dapat mengakses fitur dan data sesuai dengan hak akses (Role) yang diberikan (Admin, Petugas, Pencari).

Skenario Pengujian:

ID	Fitur	Skenario Pengujian	Hasil yang Diharapkan (Expected Result)
AUTHZ-01	Akses Publik	Mengakses endpoint publik tanpa token	Akses diizinkan (200 OK)
AUTHZ-02	Akses Private (Pencari)	Mengakses profil /me dengan token Pencari	Akses diizinkan, data profil tampil
AUTHZ-03	Akses Endpoint Admin	Pencari mengakses endpoint Admin (/logs)	Akses ditolak dengan error 403 Forbidden
AUTHZ-04	Toggle MFA	Role Pencari mengakses /toggle-mfa	Akses ditolak (403), hanya Admin & Petugas yang diizinkan
AUTHZ-05	Toggle MFA	Role Petugas mengakses /toggle-mfa	Akses diizinkan (200 OK), status MFA berubah
AUTHZ-06	Admin Akses	Admin mengakses halaman manajemen pengguna	Akses diizinkan, seluruh data pengguna dapat dikelola

3. Accounting (Pencatatan / Auditing)

Tujuan: Memastikan semua aktivitas pengguna, terutama akses dan perubahan data sensitif, tercatat dengan baik dalam sistem (Activity Logs) dan adanya pembatasan laju akses (Rate Limiting).

Skenario Pengujian :

ID	Fitur	Skenario Pengujian	Hasil yang Diharapkan (Expected Result)
ACCT-01	Log Login	Pengguna melakukan login	Sistem mencatat waktu login, IP address, dan ID pengguna di tabel log
ACCT-02	Log Transaksi	Petugas mengubah status barang temuan	Tindakan perubahan dicatat dengan informasi siapa, kapan, dan perubahan apa
ACCT-03	Log Kegagalan	Pengguna gagal login berkali-kali	Sistem mencatat upaya login gagal sebagai anomali
ACCT-04	Rate Limiting Login	Mengirim request /login > 5 kali per menit	Request ke-6 ditolak dengan kode 429 Too Many Requests
ACCT-05	Rate Limiting Register	Mengirim request /register > 3 kali per menit	Ditolak dengan 429 Too Many Requests

ACCT-06	Admin Log Review	Admin mengakses endpoint /logs	Sistem mengembalikan daftar histori aktivitas dari fungsi get_logs(db)
---------	---------------------	-----------------------------------	--